

ISO - NIST CSF Mapping and Policy Development

ISO 27001 5.16 Identity Management

Identity Management requires that every individual accessing organizational systems has a unique identity, and that identities are created, modified, and disabled in a controlled manner. This includes ensuring that accounts are approved, properly authenticated, and removed when no longer required. It also requires protections such as MFA, strong passwords, and proper verification before resetting credentials.

ISO 27001 5.15 Access Control

This control ensures that access to information and systems is granted based on job role and business needs. and must follow the **principle of least privilege** so users get the minimum required access. It also requires periodic access review, approval processes, and immediate removal of excess or outdated access rights.

ISO 27001 – 5.9 Asset Inventory

This requires organizations to identify and maintain a complete inventory of all information assets that support business operations. Assets include hardware, software, cloud resources, data repositories, and services. An accurate inventory ensures that nothing exists unmanaged or unprotected.

ISO 27001 Control	NIST CSF Reference	Simple Meaning
5.16 Identity Management	PR.AC-1, PR.AC-4	PR.AC-1 Controls identity creation, authentication, and lifecycle processes; PR.AC-4 enforces least privilege and periodic review. Both directly align with ISO's identity lifecycle and security requirements.
5.15 Access Control	PR.AC-3, PR.PT-3	PR.AC-3 covers remote and system access enforcement; PR.PT-3 supports least privilege through logical access controls. Both mirror ISO's requirement to restrict access based on job role and enforce secure access mechanisms.
Inventory & Asset Ownership	ID.AM-1, ID.AM-2	This control ensures a comprehensive inventory of asset types, locations, and assigned ownership, supporting full visibility and accountability as required by ISO 27001

Values to a Cybersecurity Analyst

- PR.AC-1, PR.AC-4 Help analysts perform access reviews, enforce MFA, manage user provisioning, and assess identity-related risks and audit trails.
- PR.AC-3, PR.PT-3 Support policy creation, role-based access design, privilege audits, and detection of access anomalies.

- ID.AM-1, ID.AM-2 Enable accurate asset tracking, risk assessments, vulnerability management, and configuration oversight.

IDENTITY MANAGEMENT POLICY

Purpose

Our Identity Management Policy aims to establish a comprehensive framework for effectively managing and controlling user identities, access privileges, and authentication mechanisms within our organization. This policy aims to provide clear guidelines and procedures for creating, maintaining, and terminating user accounts, as well as enforcing access controls and authentication standards. By implementing robust identity management practices, this policy seeks to minimize the risk of unauthorized access, data breaches, and insider threats. Through strong authentication mechanisms, role-based access controls, and regular access reviews, we strive to ensure that only authorized individuals have appropriate access privileges, protect the confidentiality and integrity of our systems and data, and maintain compliance with regulatory requirements. By prioritizing identity management, we strengthen our overall cybersecurity posture, minimize the potential for security incidents, and maintain the trust and confidence of our stakeholders.

Scope

The Identity Management Policy applies to all our organization's employees, contractors, and stakeholders. It encompasses managing and controlling user identities, access privileges, and authentication mechanisms within our IT infrastructure. This policy covers all accounts and credentials to access organizational systems, applications, and data resources. It sets forth guidelines for user provisioning, access controls, password management, and account lifecycle management to ensure information assets' integrity, confidentiality, and availability. The policy defines procedures for identity verification, role-based access control, single sign-on, and multi-factor authentication. It also outlines the responsibilities of individuals involved in identity management processes, including system administrators, IT managers, and identity administrators. Compliance with this policy is mandatory for all individuals within the organization, and any deviations or exceptions require approval from the designated authority responsible for identity management and cybersecurity governance.

Security Measures

Users must access systems only through their individually assigned accounts, protect and use MFA on those accounts, never share credentials, promptly report changes or unauthorized activity, and follow verification procedures for password resets.

4. Responsibilities

- **IT Security:** Enforces identity lifecycle controls and MFA.
- **HR:** Notifies IT of onboarding, role changes, and terminations.
- **Managers:** Approve access requests.
- **End Users:** Maintain confidentiality of authentication credentials.

References

NIST CSF PR.AC-1, PR.AC-3, PR.AC-4, PR.AC-6, PR.DS-5, and DE.CM-3

Compliance

Non-compliance with this policy may result in disciplinary action in line with our corporation's human resources procedures. Consequences may range from mandatory refresher training and written warnings to temporary suspension of remote access privileges and, in severe cases, termination of employment or contractual obligations. Individuals could be subject to legal consequences under applicable laws if violations involve illegal activities. These sanctions emphasize the critical importance of cybersecurity, the individual's role in protecting our digital assets, and the potential risks associated with policy violations. Enforcement will be consistent and impartial, with the severity of the action corresponding directly to the seriousness of the breach.

ACCESS CONTROL POLICY

Purpose

This Access Management Policy establishes governance controls for managing user identities and authentication mechanisms across the organization. This policy aims to provide clear guidelines and procedures for granting, reviewing, and revoking access privileges, ensuring that users have the appropriate level of access based on their roles and responsibilities. This policy seeks to minimize the risk of unauthorized access, data breaches, and insider threats by implementing effective access management practices. By implementing strong authentication mechanisms, role-based access controls, and regular access reviews, we strive to ensure that only authorized individuals can access sensitive information, protect the confidentiality and integrity of our systems and data, and comply with regulatory requirements. By prioritizing access management, we strengthen our overall cybersecurity posture, safeguard against unauthorized access, and maintain the trust and confidence of our stakeholders.

Scope

The Access Management Policy applies to all our organization's employees, contractors, and stakeholders. It encompasses managing and controlling user access privileges to systems, applications, and data resources within our IT infrastructure. This policy covers all accounts and credentials to authenticate and authorize individuals' access. It sets forth guidelines for user provisioning, role-based access control, and segregation of duties to ensure appropriate access levels are granted based on job responsibilities and the principle of least privilege. The policy defines user account creation, modification, and termination procedures, as well as password management, session management, and access revocation. It also outlines the responsibilities of individuals involved in access management processes, including system administrators, IT managers, and access administrators. Compliance with this policy is mandatory for all individuals within the organization, and any deviations or exceptions require approval from the designated authority responsible for access management and cybersecurity governance.

Security Measures

Access to systems and information must be based on job responsibilities and follow the principle of least privilege. Access must be granted only after management approval and must be reviewed periodically. Unnecessary or outdated access must be removed promptly. Role-based access control (RBAC) must be implemented, and direct access modification must only be done through the established approval workflow.

Responsibilities

- **IT Security:** Implements RBAC, reviews permissions, monitors privileged accounts.
- **Managers:** Validate user access during reviews.
- **End Users:** Use access only for approved business activities.

Compliance

Non-compliance with this policy may result in disciplinary action in line with our corporation's human resources procedures. Consequences may range from mandatory refresher training and written warnings to temporary suspension of remote access privileges and, in severe cases, termination of employment or contractual obligations. Individuals could be subject to legal consequences under applicable laws if violations involve illegal activities. These sanctions emphasize the critical importance of cybersecurity, the individual's role in protecting our digital assets, and the potential risks associated with policy violations. Enforcement will be consistent and impartial, with the severity of the action corresponding directly to the seriousness of the breach.

References

PR.AC-1, PR.AC-3, PR.AC-4, PR.AC-6, PR.IP-3

ASSET MANAGEMENT POLICY

Purpose

Our Asset Management Policy aims to establish a systematic and up-to-date inventory of all information technology assets within our organization, ensuring their proper management, monitoring, and protection. This policy provides clear guidelines and procedures for identifying, documenting, and tracking hardware, software, network devices, and other digital assets throughout their lifecycle. By implementing effective Asset Management practices, this policy seeks to enhance our visibility and understanding of our technology landscape, improve asset management, and strengthen cybersecurity controls. Through regular asset audits, vulnerability assessments, and risk assessments, we strive to identify and mitigate potential vulnerabilities, ensure timely patching and updates, and protect our systems, data, and networks from

unauthorized access and potential threats. By prioritizing Asset Management, we enhance our overall cybersecurity posture, enable effective risk management, and maintain our critical assets' integrity, confidentiality, and availability.

Scope

The Asset Management Policy applies to all our organization's employees, contractors, and stakeholders and encompasses the systematic identification, tracking, and management of all information technology assets within our infrastructure. This policy covers hardware devices, software applications, network components, and data repositories. It establishes procedures for conducting regular asset inventories, maintaining accurate asset ownership and location records, and updating the inventory as new assets are acquired or retired. The policy sets forth guidelines for asset discovery and monitoring techniques to identify unauthorized or unmanaged assets within the organization's network. Compliance with this policy is mandatory for all individuals within the organization, and any deviations or exceptions require approval from the designated authority responsible for asset inventory and cybersecurity governance.

Security Measures

All assets that store, process, or transmit organizational information must be documented in an asset inventory. This includes physical devices, virtual machines, cloud services, storage buckets, databases, and software. Each asset must have a designated owner responsible for monitoring, updates, classification, and lifecycle management. The inventory must be kept accurate and up-to-date and reviewed periodically.

Responsibilities.

- **IT Security:** Oversees inventory tools and ensures compliance.
- **IT Operations:** Record new assets and decommission retired assets.
- **End Users:** Must not connect unauthorized devices to the environment.

Compliance

Non-compliance with this policy may result in disciplinary action in line with our corporation's human resources procedures. Consequences may range from mandatory refresher training and written warnings to temporary suspension of remote access privileges and, in severe cases,

termination of employment or contractual obligations. Individuals could be subject to legal consequences under applicable laws if violations involve illegal activities. These sanctions emphasize the critical importance of cybersecurity, the individual's role in protecting our digital assets, and the potential risks associated with policy violations. Enforcement will be consistent and impartial, with the severity of the action corresponding directly to the seriousness of the breach.

References

D.AM-1, ID.AM-2, ID.AM-4, ID.AM-5, ID.AM-6, ID.GV-2, PR.IP-1, PR.IP-3